Session Management

Hostel Management System (HMS) — Software Requirements Specification

Purpose

Define how HMS creates, maintains, protects, and terminates authenticated user sessions for student, staff, and administrator accounts.

Session creation

- Create a session only after successful authentication and account-status checks.
- Use unpredictable session identifiers generated by a secure platform mechanism. Do not encode passwords or personal information in session identifiers.
- Regenerate the session identifier after login and after privilege changes to reduce session-fixation risk.

Session protection

- Use HTTPS for authenticated traffic in deployed environments.
- For cookie-based sessions, set Secure and HttpOnly attributes and an appropriate SameSite policy. Do not expose session identifiers to client-side scripts or URLs.
- Store session state and secrets securely. Never log session IDs, access tokens, or authentication credentials.
- Apply CSRF protection to state-changing requests when cookie-based authentication is used.

Timeout and termination

- Configure an inactivity timeout and an absolute session lifetime according to institutional security policy. The actual durations must be selected and documented by the project team.
- Provide an explicit logout function that invalidates the server-side session and clears the client-side session cookie/token.
- Terminate sessions when an account is disabled, credentials are reset, or access is revoked, according to the application's session architecture.
- Require re-authentication for sensitive actions when appropriate, such as changing credentials or performing high-impact administrative operations.

Concurrent sessions and devices

- Define whether multiple concurrent sessions are permitted. If restricted, enforce the rule consistently and inform the user when an older session is invalidated.
- Provide a way for administrators or users to revoke sessions where supported and appropriate.
- Ensure expired or revoked sessions cannot continue to access protected endpoints.

Failure and monitoring

- Reject missing, expired, malformed, or revoked session credentials with a consistent authentication response.
- Record relevant login, logout, expiration, and revocation events in the audit trail without recording the session secret itself.
- Apply rate limiting and account-protection controls to repeated authentication failures as defined by the authentication requirements.

Acceptance criteria

- A session is issued only after successful authentication.
- Session identifiers are renewed at login and protected from client-side script access where cookies are used.
- Expired, logged-out, or revoked sessions cannot access protected operations.
- Configured inactivity and absolute timeouts are enforced.
- Session secrets are not exposed in logs, URLs, or user-visible error messages.

Document note: This document defines project-level requirements for the HMS utility. Confirm implementation-specific settings (such as role names, file limits, retention periods, and timeout values) against the approved project configuration before production deployment.